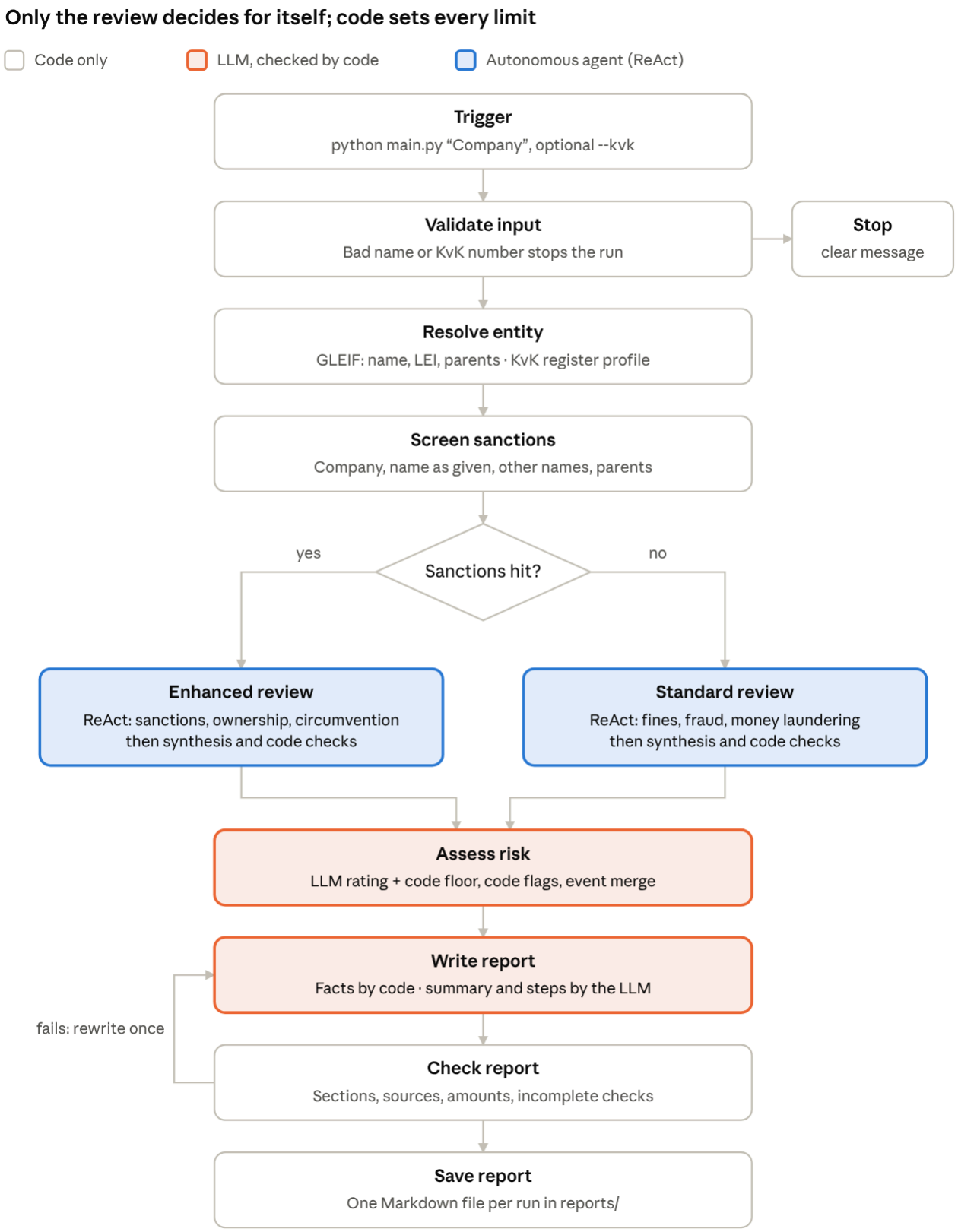
Vendor DD Agent: the Pipeline

Nov 11, 2026 · @Piet

One command runs ten steps from a company name to a saved, cited report. Only the adverse media research decides for itself; code sets every limit and checks everything the LLM writes.

At a glance



vendor due-diligence pipeline · 10 steps, 1 branch, 1 rewrite loop

A sanctions hit sends the vendor to the enhanced review; every path then meets at the risk assessment, and a report that fails the check is rewritten once before it is saved.

Step by step

Every step writes to one shared state. `errors` and `trace` are only ever appended to, so the run leaves an audit trail that ends up in section 8 of the report.

#	Step	Who decides	What it does	If it fails
0	**Trigger** (`main.py`)	Code	`python main.py "Company"`, optional `--kvk`; builds the starting state	—
1	**Validate input**	Code	Name not empty; KvK number 8 digits	Run stops with a clear message
2	**Resolve entity**	Code	GLEIF: best name match, LEI, status, former names, parents. Dutch entity: KvK number from GLEIF, then the KvK profile	Logged; doubtful match flagged; no parent adds a UBO note
3	**Screen sanctions**	Code	Company, name as given, former names and parents vs OpenSanctions (threshold 85, 95 for short names); one line per listed entity	Logged; `screening_complete` set to false
4	**Route**	Code	Any hit goes to enhanced review, no hit to standard	—
5	**Review** (standard or enhanced)	ReAct agent, then LLM	Phase 1: the agent chooses its own news and guidance searches (budget 6). Phase 2: one tool-free call turns the evidence into findings. Code then drops unverified URLs, articles not about the company and unverified amounts	Search failure sets `media_complete` to false; evidence found so far is kept
6	**Assess risk**	LLM, checked by code	LLM gives rating, red flags, recommendation. Code adds sanctions and identity flags, merges flags per event, removes unverified sources, enforces the minimum rating	Code rules alone set the rating

#	Step	Who decides	What it does	If it fails
7	**Write report**	Code + LLM	Sections 2–6 and 8 filled by code; summary, recommendation text and specific steps by the LLM; standard next steps by code	Fallback text from the code rules
8	**Check report**	Code	All 8 sections, every source visible, no unverified amounts, incomplete checks stated	Back to step 7 once with the problems as feedback
9	**Save report**	Code	`reports/<company>_<date>.md`	Saved with a warning if the check failed twice

Safeguards

The LLM may rate a vendor higher than the code rules, never lower. When several rules apply, the strictest one wins.

Situation	Minimum set by code
Strong sanctions match on the company, on an EU or UK program	High · Do not onboard
Other strong sanctions match on the company	High · Escalate
Possible sanctions match (score 85–94, or via a parent)	Medium · Escalate
Sanctions screening incomplete	Medium · Escalate
Identity not verified (no LEI and no KvK profile)	Medium · Escalate
Adverse media check incomplete (search failed)	Medium · Onboard with conditions
None of the above	Low · Onboard

Check on the LLM	What happens when it fails
Finding URL must come from the news tool	Finding dropped
Article must name the company	Finding dropped

Check on the LLM	What happens when it fails
Amount must appear in the raw article text	Summary replaced by the source excerpt, or the report is rewritten
Guidance reference must have been retrieved	Reference removed
Same event reported twice	Merged into one red flag with several sources
Settled case labelled "investigation"	Relabelled

Every correction is logged in section 8 of the report.

What is autonomous, and why only that

The whole run is autonomous: nobody intervenes between the command and the saved report. Only the research phase of the review makes its own decisions: which searches to run, which leads to follow, which guidance to look up, and when to stop.

- **Mandatory checks must run every time, the same way.** A sanctions check an agent sometimes skips is worse than no check.
- **Adverse media is open-ended.** How many searches it takes, and which leads appear, cannot be known in advance.
- **Decisions must be explainable.** A compliance officer has to defend why a vendor was approved or rejected; fixed rules can be explained, free agent choices cannot.
- **Testing showed limits belong in code.** The agent once ignored a "budget used up" message nine times, and the LLM added amounts up despite a rule against it.

In one sentence: the agent has freedom where the work is open-ended, and the decisions a compliance officer must defend are fixed in code.